Control and evidence register

Reviewed application control families across the HRO Control Tower, API, unified context manager and Employee Vault. Cost Explorer figures are estimates, not security or outcome assurance. This is a code-and-content inventory, not a production configuration audit, penetration test or certification.

50 reviewed controls · 8 control families · 12 metric/evidence definitions
Plus 5 roadmap areas and 6 deployment-evidence categories.

Implemented

An application control exists; this does not establish live effectiveness.

Configuration required

The framework exists, but approved policies, authority, providers or evidence are prerequisites.

Roadmap

The additional capability described is not established as a completed feature in this review.

Deployment evidence not verified

A deployment, contractual or operational fact requiring separate evidence; not a claim of absence.

Review method and limits

Reconciled documented controls with current source boundaries, the communications guardrail catalogue, the analytics definitions and expiry-notice implementation. Source pointers were checked for existence. Test pointers identify nearby automated checks, not successful execution or complete coverage. No tenant records, credentials, live metric values or provider configuration were collected. This is comprehensive across the listed reviewed control families, not a guarantee that no undiscovered control or gap exists.

Accountability

Reviewer roles below are suggested evidence owners, not assigned people or certified accountability. Obtain dated tenant-specific policy, configuration, test and provider evidence before claiming operational assurance.

Business use cases are fictional illustrations of when each control matters, not records of executed checks, measured effectiveness or certification.

Identity and authority

Suggested evidence reviewer: Security / access-governance reviewer

SEC-01 · Authenticated operational access

Status: Implemented

Risk addressed: Unauthorized record access, privilege escalation or unverified professional authority.

Control: Signed-in identity is required for operational API access; provider callbacks have separate verification boundaries.

Business use case: An HR coordinator opens the onboarding queue from a shared laptop. Requiring sign-in prevents an unauthenticated visitor from viewing or changing operational records.

Safe behavior: Unauthorized access is rejected.

Limit / residual risk: Authentication does not grant organization, case or specialist authority.

Source: artifacts/api-server/src/lib/onboarding/guardrails.ts; artifacts/api-server/src/lib/access-governance.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/onboarding/guardrails.test.ts; artifacts/api-server/src/lib/access-governance.test.ts

SEC-02 · Organization and case isolation

Status: Implemented

Risk addressed: Unauthorized record access, privilege escalation or unverified professional authority.

Control: Application-owned organizations and subject scopes constrain access to client records.

Business use case: An implementation team supports two client organizations. A reviewer working on one client's hire must not open the other client's case by changing a record identifier.

Safe behavior: Cross-scope requests are denied.

Limit / residual risk: Tenant membership alone is not permission for every case or record.

Source: artifacts/api-server/src/lib/access-governance.ts; artifacts/api-server/src/lib/onboarding/sensitive-access.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/access-governance.test.ts; artifacts/api-server/src/lib/onboarding/sensitive-access.test.ts

SEC-03 · Group, field and tool permissions

Status: Implemented

Risk addressed: Unauthorized record access, privilege escalation or unverified professional authority.

Control: Access groups and scoped permissions govern eligible flows, fields and tools.

Business use case: An equipment coordinator needs laptop-delivery details, not background-check findings. Scoped permissions restrict the fields and actions available for that role.

Safe behavior: Disallowed reads or actions are blocked.

Limit / residual risk: Coverage must be checked for each new endpoint and tool.

Source: artifacts/api-server/src/lib/access-governance.ts; artifacts/api-server/src/lib/agent-invocation.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/access-governance.test.ts; artifacts/api-server/src/lib/agent-invocation.test.ts

SEC-04 · Temporary access and lifecycle fencing

Status: Implemented

Risk addressed: Unauthorized record access, privilege escalation or unverified professional authority.

Control: Time-bounded grants and membership lifecycle state are evaluated against current access.

Business use case: A contractor receives access for a one-week onboarding project. When the grant expires or is revoked, it must not authorize another case lookup or action.

Safe behavior: Expired or revoked grants cannot authorize subsequent work.

Limit / residual risk: Race-sensitive flows need ongoing regression evidence; expiry is not a historical audit rewrite.

Source: artifacts/api-server/src/lib/access-governance.ts; artifacts/api-server/src/routes/hro-context.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/access-governance.test.ts

SEC-05 · Verified specialist authority

Status: Configuration required

Risk addressed: Unauthorized record access, privilege escalation or unverified professional authority.

Control: Professional governance authority is distinct from tenant administration and mailbox personas.

Business use case: A workspace administrator wants to approve a legal exception. Administration alone is insufficient; the applicable professional-authority approval must be established before the specialist action.

Safe behavior: Missing or unverified authority blocks specialist actions.

Limit / residual risk: Authority must be established through the applicable approval process.

Source: artifacts/api-server/src/lib/onboarding/governance-runtime.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/onboarding/governance-runtime.test.ts

SEC-06 · Versioned approvals and policies

Status: Implemented

Risk addressed: Unauthorized record access, privilege escalation or unverified professional authority.

Control: Consequential work uses approved policy revisions and evidence-bound review rather than unreviewed drafts.

Business use case: HR changes a readiness requirement after reviewing a hire. Work must follow the approved revision, and changed evidence requires review rather than inheriting an old approval.

Safe behavior: Changed evidence or missing approvals require review.

Limit / residual risk: A new policy cannot prove the rationale of an older decision.

Source: artifacts/api-server/src/lib/onboarding/governance-runtime.ts; artifacts/api-server/src/lib/onboarding/dispatch-guard.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/onboarding/governance-runtime.test.ts

SEC-07 · Registered agent identity

Status: Implemented

Risk addressed: Unauthorized record access, privilege escalation or unverified professional authority.

Control: Agent identity and version are resolved against server-side registration and permitted execution scope.

Business use case: A team introduces a new payroll agent. Server-side registration and permitted scope must be checked before it can execute work, rather than trusting its claimed role.

Safe behavior: Unknown or unauthorized executors are rejected.

Limit / residual risk: Client-supplied role or permission claims are not authority.

Source: artifacts/api-server/src/lib/agent-invocation.ts; artifacts/api-server/src/lib/hro-context/core.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/agent-invocation.test.ts

SEC-08 · Candidate-link access lifecycle

Status: Implemented

Risk addressed: Unauthorized record access, privilege escalation or unverified professional authority.

Control: Candidate portal credentials and access records are scoped and expire; eligible metadata has a separate cleanup lifecycle.

Business use case: A candidate receives a link to upload onboarding documents. The link provides only scoped portal access and cannot authorize uploads after expiry or unlock the full Control Tower.

Safe behavior: Invalid or expired links cannot authorize portal operations.

Limit / residual risk: Portal access is not full Control Tower access; active links are not deleted just for metadata age.

Source: artifacts/api-server/src/lib/onboarding/candidate-portal.ts; artifacts/api-server/src/lib/onboarding/candidate-access-cleanup.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/onboarding/candidate-portal.test.ts; artifacts/api-server/src/lib/onboarding/candidate-access-cleanup.test.ts

SEC-09 · Hashed portal credentials and exchange throttling

Status: Implemented

Risk addressed: Unauthorized record access, privilege escalation or unverified professional authority.

Control: Candidate token/session secrets are hashed for lookup; bounded failure records and cooldowns constrain exchange attempts.

Business use case: Someone repeatedly guesses a candidate's portal credentials. Hashed credential lookup and exchange cooldowns limit these attempts without storing the lookup secrets in plain text.

Safe behavior: Repeated invalid exchange attempts are throttled; expired or revoked link/session bindings fail.

Limit / residual risk: These controls protect the candidate portal, not every authentication provider or application endpoint.

Source: artifacts/api-server/src/lib/onboarding/candidate-portal.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/onboarding/candidate-portal.test.ts

Communication safety and abuse prevention

Suggested evidence reviewer: Security / communication-channel owner

COM-01 · Signed webhook verification

Status: Implemented

Risk addressed: Forged, misrouted, duplicated or runaway external communication.

Control: Twilio callbacks are signature-validated; voice callbacks also bind to the expected call identity.

Business use case: A forged callback claims a candidate completed a phone interaction. Signature and expected-call checks reject the callback before it changes the case.

Safe behavior: Forged callbacks are rejected before influencing state.

Limit / residual risk: Applies to configured channel boundaries; it is not a universal vendor identity guarantee.

Source: artifacts/api-server/src/lib/onboarding/guardrails.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/onboarding/guardrails.test.ts

COM-02 · Trusted status senders

Status: Configuration required

Risk addressed: Forged, misrouted, duplicated or runaway external communication.

Control: Configured sender allowlists gate external status-email processing; an unset list trusts nobody.

Business use case: An email claims that a background check is complete. Only a configured trusted sender can enter status processing; case and evidence checks still apply.

Safe behavior: Untrusted status messages do not change checks.

Limit / residual risk: A trusted sender still needs the applicable case binding and evidence checks.

Source: artifacts/api-server/src/lib/onboarding/guardrails.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/onboarding/guardrails.test.ts

COM-03 · Case binding and replay protection

Status: Implemented

Risk addressed: Forged, misrouted, duplicated or runaway external communication.

Control: Inbound communication is subject-bound, with provider-message deduplication and self-echo protection.

Business use case: A verification provider resends a status email to a mailbox shared by multiple clients. Case binding and deduplication prevent applying it to the wrong hire or acting twice.

Safe behavior: Unmatched, ambiguous or duplicate messages do not drive new effects.

Limit / residual risk: Sender identity alone cannot establish tenant or specialist authority.

Source: artifacts/api-server/src/lib/onboarding/guardrails.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/onboarding/guardrails.test.ts

COM-04 · Recipient and volunteer restrictions

Status: Implemented

Risk addressed: Forged, misrouted, duplicated or runaway external communication.

Control: External messages and calls require authorized recipients; demo volunteer authorization is explicit.

Business use case: A salesperson demonstrates candidate outreach. Messages must stay within explicitly authorized recipients; a demo persona or delivery receipt does not grant stakeholder approval.

Safe behavior: Unauthorized delivery is blocked or recorded as logged-only.

Limit / residual risk: A delivery record is not proof of stakeholder approval or completed employment work.

Source: artifacts/api-server/src/lib/onboarding/guardrails.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/onboarding/guardrails.test.ts

COM-05 · Send and call caps

Status: Implemented

Risk addressed: Forged, misrouted, duplicated or runaway external communication.

Control: Communication limits and voice-turn serialization constrain runaway activity and replays.

Business use case: A delayed reply causes repeated follow-up attempts. Send caps and call serialization constrain repeated outreach instead of allowing an uncontrolled sequence of messages or calls.

Safe behavior: Excess or overlapping work is rate-limited, held or safely ended.

Limit / residual risk: These are scoped controls, not evidence of an enterprise-wide denial-of-service guarantee.

Source: artifacts/api-server/src/lib/onboarding/guardrails.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/onboarding/guardrails.test.ts

COM-06 · Bounded voice interaction

Status: Implemented

Risk addressed: Forged, misrouted, duplicated or runaway external communication.

Control: Voice accepts fixed structured decisions with bounded speech, output and conversation turns.

Business use case: A candidate asks the voice assistant to promise an employment exception. The bounded interaction can route the request to a human rather than making an unauthorized commitment.

Safe behavior: Unsafe or invalid output routes to a human callback or ends safely.

Limit / residual risk: Successful voice exchange does not authorize record changes or professional commitments.

Source: artifacts/api-server/src/lib/onboarding/guardrails.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/onboarding/guardrails.test.ts

Privacy and data lifecycle

Suggested evidence reviewer: Privacy / legal reviewer

PRI-01 · Sensitive collection and disclosure policy

Status: Configuration required

Risk addressed: Unauthorized sensitive disclosure, excessive retention or unsafe deletion.

Control: Approved, versioned policies govern sensitive collection and disclosure at the relevant boundary.

Business use case: HR wants to collect health-related onboarding information. The applicable sensitive-data policy and approvals must be established before collection or disclosure; admin access is not a lawful basis.

Safe behavior: Unknown classification or missing approval can block handling.

Limit / residual risk: Administrative access does not establish a lawful processing basis.

Source: artifacts/api-server/src/lib/onboarding/sensitive-access.ts; artifacts/api-server/src/lib/onboarding/sensitive-lifecycle.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/onboarding/sensitive-access.test.ts; artifacts/api-server/src/lib/onboarding/sensitive-lifecycle.test.ts

PRI-02 · Opaque-content confidentiality

Status: Implemented

Risk addressed: Unauthorized sensitive disclosure, excessive retention or unsafe deletion.

Control: Free text and opaque subject material are not presumed public or harmless.

Business use case: A coordinator pastes an unexplained note into a case. Because it may contain sensitive information, the text is not treated as safe for unrestricted disclosure.

Safe behavior: Unclassified sensitive material is withheld from unauthorized use.

Limit / residual risk: Each new content type needs conservative classification and disclosure coverage.

Source: artifacts/api-server/src/lib/onboarding/sensitive-access.ts; artifacts/api-server/src/lib/onboarding/sensitive-lifecycle.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/onboarding/sensitive-access.test.ts; artifacts/api-server/src/lib/onboarding/sensitive-lifecycle.test.ts

PRI-03 · Minimized and masked evidence

Status: Implemented

Risk addressed: Unauthorized sensitive disclosure, excessive retention or unsafe deletion.

Control: Domain builders restrict model evidence; communication audit paths mask contacts and bound input snippets.

Business use case: A coordinator investigates a failed candidate message. Masked contact details and bounded audit snippets reduce unnecessary exposure while relevant model inputs remain subject to sanitization or rejection.

Safe behavior: Inputs are sanitized or rejected at relevant boundaries.

Limit / residual risk: Scoped masking is not proof that all stored records are anonymous.

Source: artifacts/api-server/src/lib/onboarding/guardrails.ts; artifacts/api-server/src/lib/onboarding/sensitive-access.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/onboarding/guardrails.test.ts; artifacts/api-server/src/lib/onboarding/sensitive-access.test.ts

PRI-04 · Retention, deletion and legal holds

Status: Configuration required

Risk addressed: Unauthorized sensitive disclosure, excessive retention or unsafe deletion.

Control: Sensitive-record cleanup uses reviewed policy and hold-aware lifecycle controls.

Business use case: A departed employee's records reach their retention date during a legal dispute. An active hold prevents eligible cleanup until the approved lifecycle permits deletion.

Safe behavior: Active holds or unsafe lifecycle state prevent eligible cleanup.

Limit / residual risk: Retention periods are approved by the client; no universal statutory period is invented.

Source: artifacts/api-server/src/lib/onboarding/sensitive-lifecycle.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/onboarding/sensitive-lifecycle.test.ts

PRI-05 · Metadata-only unified context

Status: Implemented

Risk addressed: Unauthorized sensitive disclosure, excessive retention or unsafe deletion.

Control: Context history records scope, identifiers, statuses and bounded metrics, not prompts, answers or documents.

Business use case: A support analyst traces an interrupted workflow. Metadata can describe scope, steps and status without turning the shared context history into a store of employee documents or model conversations.

Safe behavior: Cross-tenant or cross-actor context inheritance is rejected.

Limit / residual risk: Business records and protected audit evidence have separate retention rules.

Source: artifacts/api-server/src/lib/hro-context/core.ts; artifacts/api-server/src/lib/hro-context/manager.ts

PRI-06 · Safe context-history pruning

Status: Configuration required

Risk addressed: Unauthorized sensitive disclosure, excessive retention or unsafe deletion.

Control: Approved rules govern bounded cleanup of eligible complete chains while preserving unsafe or unfinished chains.

Business use case: Operations wants to remove old execution history. Approved pruning preserves held or unfinished chains rather than deleting them merely because they fall outside the screen's display window.

Safe behavior: Holds, unfinished or unsafe chains prevent pruning.

Limit / residual risk: A display window is not retention; pruning is not deletion of all business evidence.

Source: artifacts/api-server/src/lib/hro-context/retention.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/hro-context/retention.test.ts

PRI-07 · Restricted aggregate analytics

Status: Implemented

Risk addressed: Unauthorized sensitive disclosure, excessive retention or unsafe deletion.

Control: Analytics bounds disclosure and uses a local deterministic narrative instead of sending opaque cohort content to a model.

Business use case: A manager requests an onboarding summary for a sensitive cohort. Restricted disclosure and a local narrative avoid sending opaque cohort content to a model or releasing unauthorized forecasts.

Safe behavior: Unauthorized sensitive forecasts are withheld.

Limit / residual risk: A privacy badge or threshold label is not proof of full differential privacy or safe release of every cohort.

Source: artifacts/api-server/src/routes/onboarding.ts; artifacts/onboarding-agent/src/pages/analytics.tsx

Documents and employee-owned evidence

Suggested evidence reviewer: Security / verification / privacy reviewers

DOC-01 · Private bounded upload lifecycle

Status: Implemented

Risk addressed: Unsafe, forged, stale or unconsented document reuse.

Control: Scoped upload reservations and bounded file handling track completion and interrupted writes.

Business use case: A candidate's connection drops halfway through a document upload. The incomplete write must not become accepted evidence; scoped upload tracking distinguishes it from a completed submission.

Safe behavior: Incomplete or invalid writes cannot become accepted evidence.

Limit / residual risk: An upload signature alone does not bind all size/type restrictions.

Source: artifacts/api-server/src/lib/onboarding/candidate-upload-reservations.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/onboarding/candidate-upload-reservations.test.ts

DOC-02 · Malware quarantine and evidence gates

Status: Implemented

Risk addressed: Unsafe, forged, stale or unconsented document reuse.

Control: Malware state and current evidence gates govern whether a document may be used for readiness.

Business use case: An apparently genuine certificate is flagged by the malware scanner. It remains quarantined and cannot support readiness merely because an authenticity check looks favorable.

Safe behavior: Quarantined or unavailable safety evidence cannot be bypassed by authenticity claims.

Limit / residual risk: Live scan results require a configured scanner; clean files can still be forged.

Source: artifacts/api-server/src/lib/onboarding/document-malware-gate.ts; artifacts/api-server/src/lib/onboarding/malware-scanner-monitor.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/onboarding/malware-scanner-monitor.test.ts

DOC-03 · Document validation versus authenticity

Status: Implemented

Risk addressed: Unsafe, forged, stale or unconsented document reuse.

Control: Local file validation is distinguished from source-backed verification and human review.

Business use case: A certificate uploads successfully, but its issuer cannot be verified. HR sees an unresolved verification question requiring review, not a claim that file validation proves authenticity.

Safe behavior: Unavailable, uncertain or adverse results require review.

Limit / residual risk: Readable text, matching fields or an AI plausibility score do not authenticate a document.

Source: artifacts/api-server/src/lib/onboarding/document-validation.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/onboarding/document-validation.test.ts

DOC-04 · Independent Employee Vault ownership

Status: Implemented

Risk addressed: Unsafe, forged, stale or unconsented document reuse.

Control: Employee profiles are separately owned; registration does not confer employer or reviewer roles.

Business use case: An employee stores a credential in their personal Vault while changing employers. Membership in either employer organization does not let administrators act as the employee or control that personal evidence.

Safe behavior: Other users cannot act as the employee merely through organization membership.

Limit / residual risk: A personal Vault account is not proof of employer identity binding.

Source: artifacts/api-server/src/lib/employee-vault/core.ts

DOC-05 · Signed source and revision binding

Status: Configuration required

Risk addressed: Unsafe, forged, stale or unconsented document reuse.

Control: Approved issuer keys verify signed results bound to profile, jurisdiction, document revision and content digest.

Business use case: An employee replaces a verified credential with a newer file. The old provider receipt cannot verify the replacement; reuse needs a current matching source and revision binding.

Safe behavior: Changed, expired or mismatched bindings cannot establish current reuse.

Limit / residual risk: Cryptography proves an accepted issuer's statement, not that every issuer or document type is supported.

Source: artifacts/api-server/src/lib/employee-vault/verification.ts

DOC-06 · Consent, complete requirements and revocation

Status: Implemented

Risk addressed: Unsafe, forged, stale or unconsented document reuse.

Control: Reuse requires current employee consent, employer-case binding and all required eligible checks.

Business use case: A new employer requires several background checks, but the employee shares evidence for only one. Partial verification or expired consent cannot satisfy the complete reuse requirements.

Safe behavior: Partial verification, expired consent or revoked sharing cannot satisfy full reuse.

Limit / residual risk: Revocation stops future sharing; it does not undo earlier lawful disclosures.

Source: artifacts/api-server/src/lib/employee-vault/reuse.ts

DOC-07 · Private opt-in expiry notices

Status: Implemented

Risk addressed: Unsafe, forged, stale or unconsented document reuse.

Control: Employee-owned in-app notices warn of eligible verification or sharing expiry under a separate preference.

Business use case: An employee opts into a private reminder before a credential expires. The notice prompts review without renewing the credential, assuming an email identity or notifying others automatically.

Safe behavior: Disabled, stale or no-longer-eligible notices are not disclosed.

Limit / residual risk: Notices do not renew checks, extend consent or imply verified email delivery.

Source: artifacts/api-server/src/lib/employee-vault/expiry-notices.ts

Responsible AI and answer boundaries

Suggested evidence reviewer: AI assurance / domain-policy reviewer

AI-01 · Approved extractive policy answers

Status: Implemented

Risk addressed: Unsupported, manipulated or harmful AI-supported answers and actions.

Control: The assistant selects an authorized approved extract with a constrained identifier and exact quotation validation.

Business use case: An employee asks how many leave days a policy allows. The assistant can quote an approved extract, but missing or conflicting evidence must not become an invented entitlement.

Safe behavior: Insufficient, conflicting or injected content can prevent an answer.

Limit / residual risk: Exact quote validity is not a measured end-to-end answer-correctness guarantee.

Source: artifacts/api-server/src/lib/hr-policy-ai.ts

AI-02 · Prompt-injection evidence fencing

Status: Implemented

Risk addressed: Unsupported, manipulated or harmful AI-supported answers and actions.

Control: Inbound text and speech are treated as evidence, with structured output and restricted state decisions.

Business use case: An uploaded document includes an instruction to ignore checks and approve the hire. The instruction is treated as untrusted content, not authority to change the workflow.

Safe behavior: Instruction-like, contradictory or risky content is escalated instead of accepted as authority.

Limit / residual risk: Defense is layered risk reduction, not proof that every possible injection is defeated.

Source: artifacts/api-server/src/lib/onboarding/guardrails.ts; artifacts/api-server/src/lib/hr-policy-ai.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/onboarding/guardrails.test.ts

AI-03 · Sensitive-topic human handoff

Status: Implemented

Risk addressed: Unsupported, manipulated or harmful AI-supported answers and actions.

Control: Deterministic sensitive-topic gates suppress automated AI replies and request human review.

Business use case: A candidate raises a medical accommodation question. The assistant uses a holding or human-escalation path rather than attempting to resolve a sensitive matter automatically.

Safe behavior: Sensitive questions receive a holding or escalation path.

Limit / residual risk: Human review itself does not guarantee correctness or fairness.

Source: artifacts/api-server/src/lib/onboarding/guardrails.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/onboarding/guardrails.test.ts

AI-04 · No automated adverse employment decisions

Status: Implemented

Risk addressed: Unsupported, manipulated or harmful AI-supported answers and actions.

Control: Adverse background-check or core-data exceptions pause orchestration for appropriate human approval.

Business use case: A model identifies a concerning background-check detail. HR must review the matter; the model's output alone cannot reject the candidate or clear the case.

Safe behavior: Automation cannot simply reject or clear the case from model output.

Limit / residual risk: Review quality and lawful criteria still require domain governance.

Source: artifacts/api-server/src/lib/onboarding/guardrails.ts; artifacts/api-server/src/lib/onboarding/dispatch-guard.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/onboarding/guardrails.test.ts

AI-05 · Strict AI request budgets

Status: Implemented

Risk addressed: Unsupported, manipulated or harmful AI-supported answers and actions.

Control: Exact registered model payloads receive conservative input-size and output-allocation checks.

Business use case: A workflow prepares an unusually large evidence request. Budget checks reject an oversized request instead of silently dropping mandatory evidence to fit the model limit.

Safe behavior: Oversized or invalid requests are rejected without silently truncating mandatory evidence.

Limit / residual risk: Input bytes are a conservative token bound; output allocation is not actual token usage.

Source: artifacts/api-server/src/lib/hro-context/ai-budget.ts; artifacts/api-server/src/lib/hro-context/manager.ts

AI-06 · Recorded-evidence explanations

Status: Implemented

Risk addressed: Unsupported, manipulated or harmful AI-supported answers and actions.

Control: Case explanations remain read-only and distinguish recorded evidence from hidden model reasoning or invented historical rationale.

Business use case: A reviewer asks why a case was delayed. The explanation uses recorded events and identifies evidence gaps rather than inventing a rationale from today's policy.

Safe behavior: Missing historical evidence cannot be replaced by a confident explanation.

Limit / residual risk: Present policy does not establish why an earlier decision occurred.

Source: artifacts/api-server/src/lib/onboarding/case-explainability.ts

AI-07 · Fresh citation and answer disclosure

Status: Implemented

Risk addressed: Unsupported, manipulated or harmful AI-supported answers and actions.

Control: Policy answers recheck current source, publication, applicability and disclosure authorization after model selection and at citation access.

Business use case: An employee opens a saved policy answer after the source is withdrawn. Fresh source and access checks prevent presenting the old citation as currently supported or authorized.

Safe behavior: Changed or no-longer-authorized source material cannot be disclosed as a current supported answer.

Limit / residual risk: The check guards freshness and authority; it is not a semantic accuracy score.

Source: artifacts/api-server/src/lib/hr-policy-library.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/hr-policy-library.test.ts

Agent execution and unified context harness

Suggested evidence reviewer: Platform engineering / security reviewer

RUN-01 · Scoped transaction continuity

Status: Implemented

Risk addressed: Cross-scope execution, stale authority or duplicated/ambiguous remote effects.

Control: Organization, subject, correlation, parent attempt, initiator and executor/version define execution continuity.

Business use case: An agent resumes work from an earlier step. Continuity checks ensure the parent, tenant, actor and executor match rather than allowing another client's execution context to be inherited.

Safe behavior: Invalid tenant, actor, executor or parent scope is rejected.

Limit / residual risk: The manager is continuity metadata, not authority, business evidence or a second workflow engine.

Source: artifacts/api-server/src/lib/hro-context/core.ts; artifacts/api-server/src/lib/hro-context/manager.ts

RUN-02 · Fresh dispatch eligibility

Status: Implemented

Risk addressed: Cross-scope execution, stale authority or duplicated/ambiguous remote effects.

Control: Final dispatch gates recheck authority, holds, policy and evidence at the consequential action boundary.

Business use case: A hire's approval is withdrawn just before an external work request. Fresh dispatch checks block the effect even if an earlier screen showed the prerequisites as satisfied.

Safe behavior: Stale or withdrawn prerequisites block effects.

Limit / residual risk: A preliminary status read or older successful log is not permission to act now.

Source: artifacts/api-server/src/lib/onboarding/dispatch-guard.ts; artifacts/api-server/src/lib/agent-invocation.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/agent-invocation.test.ts

RUN-03 · Durable effect journal

Status: Implemented

Risk addressed: Cross-scope execution, stale authority or duplicated/ambiguous remote effects.

Control: Remote effects use durable claims and stable logical-operation identity with provider idempotency where supported.

Business use case: A ticket request times out after it may have reached the provider. The durable effect journal preserves the uncertainty for reconciliation rather than blindly creating a second ticket.

Safe behavior: Ambiguous non-idempotent outcomes stop for reconciliation rather than blind redispatch.

Limit / residual risk: Database fencing cannot substitute for a provider's idempotency contract.

Source: artifacts/api-server/src/lib/onboarding/effect-journal.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/onboarding/effect-journal.test.ts

RUN-04 · Recovery and concurrency fencing

Status: Implemented

Risk addressed: Cross-scope execution, stale authority or duplicated/ambiguous remote effects.

Control: Checkpoints, owner-fenced claims and conditional completion guard resumed or simultaneous work.

Business use case: Two workers attempt to resume the same workflow after a restart. Ownership and checkpoint fencing stop a stale worker from finalizing work newly claimed by the other.

Safe behavior: Stale owners cannot finalize newly claimed work.

Limit / residual risk: Unfinished attempts are not automatically business failures or completed outcomes.

Source: artifacts/api-server/src/lib/onboarding/effect-journal.ts; artifacts/api-server/src/lib/hro-context/manager.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/onboarding/effect-journal.test.ts

RUN-05 · History disclosure permission

Status: Implemented

Risk addressed: Cross-scope execution, stale authority or duplicated/ambiguous remote effects.

Control: Personal and separately authorized operator history use live scoped checks, filters and older-page navigation.

Business use case: A support colleague requests execution history for a restricted case. Current disclosure permissions govern the response; knowing the history identifier is not permission to view it.

Safe behavior: Unauthorized history disclosure is denied.

Limit / residual risk: History access is not a grant to retry actions; shared demo personas do not establish personal attribution.

Source: artifacts/api-server/src/routes/hro-context.ts

RUN-06 · Detached background identity

Status: Implemented

Risk addressed: Cross-scope execution, stale authority or duplicated/ambiguous remote effects.

Control: Background work must establish its own tenant/executor context instead of inheriting a heartbeat caller's authority.

Business use case: A scheduled background worker runs after an HR user's request ends. It must use explicit scoped identity rather than borrowing that user's or another client's ambient permissions.

Safe behavior: Cross-actor or cross-tenant continuation cannot borrow ambient identity.

Limit / residual risk: Worker scheduling and availability require separate operational assurance.

Source: artifacts/api-server/src/lib/hro-context/core.ts

Audit and operational assurance

Suggested evidence reviewer: Audit / security operations reviewer

AUD-01 · Protected append-only audit

Status: Implemented

Risk addressed: Undetected tampering, unready regulated launch or silent loss of safety services.

Control: Protected audit records and tamper-evident chain verification retain consequential action evidence.

Business use case: An auditor reviews an approval trail after a suspected record change. Chain verification can reveal inconsistency instead of treating altered local history as verified evidence.

Safe behavior: Detected inconsistency prevents treating the chain as verified.

Limit / residual risk: A privileged rewrite of a local chain requires independent evidence to detect.

Source: artifacts/api-server/src/lib/onboarding/protected-audit.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/onboarding/protected-audit.test.ts

AUD-02 · Independent audit anchoring

Status: Configuration required

Risk addressed: Undetected tampering, unready regulated launch or silent loss of safety services.

Control: An approved external provider verifies generation-bound checkpoints and independent archive, restore and hold-drill receipts.

Business use case: A regulated client needs independently protected audit evidence. Configured external receipts and tested protection are required; a local audit record alone cannot establish independent readiness.

Safe behavior: Missing, stale or mismatched protection evidence blocks readiness.

Limit / residual risk: Framework existence is not proof that a client's live provider is connected; protection added today does not certify earlier records.

Source: artifacts/api-server/src/lib/onboarding/external-audit-anchor.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/onboarding/external-audit-anchor.test.ts

AUD-03 · Opt-in regulated launch guard

Status: Configuration required

Risk addressed: Undetected tampering, unready regulated launch or silent loss of safety services.

Control: Explicitly selected regulated tenants must satisfy protected audit and external archive readiness before startup proceeds.

Business use case: A client opts into regulated launch safeguards. If the required audit protection or archive readiness cannot be verified, startup is blocked rather than silently launching without those safeguards.

Safe behavior: Unverifiable or unready selected tenants block regulated production startup.

Limit / residual risk: Not every tenant or deployment automatically has this opt-in safeguard enabled.

Source: artifacts/api-server/src/lib/regulated-production-startup-guard.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/regulated-production-startup-guard.test.ts

AUD-04 · Scanner outage monitoring

Status: Configuration required

Risk addressed: Undetected tampering, unready regulated launch or silent loss of safety services.

Control: Scanner health and durable outage handling support explicit degraded-state visibility and alerts.

Business use case: The document scanner becomes unavailable during onboarding. Degraded-state visibility and configured alerts help reviewers respond; unavailable scan evidence must not be reported as clean.

Safe behavior: Unavailable safety evidence remains unavailable instead of becoming a clean scan.

Limit / residual risk: Alerts need configured channels and delivery evidence; monitoring is not uptime certification.

Source: artifacts/api-server/src/lib/onboarding/malware-scanner-monitor.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/onboarding/malware-scanner-monitor.test.ts

Testing harness and truthful demonstrations

Suggested evidence reviewer: Quality assurance / security reviewer

TST-01 · Guardrail catalogue and interventions

Status: Implemented

Risk addressed: Mistaking limited test, synthetic or demo evidence for live assurance.

Control: The Guardrails screen identifies enforcement mechanisms, evidence pointers and recorded blocked, rejected or escalated activity.

Business use case: A security reviewer investigates blocked outreach. The guardrail catalogue and recorded interventions show relevant boundaries, while the displayed count is not treated as total attack volume.

Safe behavior: Recording is bounded against abuse; enforcement remains distinct from display counts.

Limit / residual risk: The 13 communication guardrails are a subset of this inventory; counts are not exhaustive attack-volume estimates.

Source: artifacts/api-server/src/lib/onboarding/guardrails.ts; artifacts/onboarding-agent/src/pages/guardrails.tsx

Nearby test pointers, not run: artifacts/api-server/src/lib/onboarding/guardrails.test.ts

TST-02 · Controlled security drill

Status: Implemented

Risk addressed: Mistaking limited test, synthetic or demo evidence for live assurance.

Control: Synthetic attack scenarios exercise selected real enforcement boundaries with protected delivery-deny conditions.

Business use case: A team rehearses a forged-message attack using synthetic cases. The drill exercises selected enforcement boundaries and aborts if unexpected live delivery becomes possible.

Safe behavior: Unexpected live authorization or delivery aborts the drill.

Limit / residual risk: A scenario pass is not a comprehensive penetration test or fresh independent audit.

Source: artifacts/api-server/src/lib/onboarding/security-drill.ts; artifacts/onboarding-agent/src/pages/guardrails.tsx

Nearby test pointers, not run: artifacts/api-server/src/lib/onboarding/security-drill.test.ts

TST-03 · UAT evidence and isolated fixtures

Status: Implemented

Risk addressed: Mistaking limited test, synthetic or demo evidence for live assurance.

Control: UAT distinguishes observed workflow evidence, run-owned fixtures, blocked steps and manual work.

Business use case: An implementation lead reviews a UAT run with a blocked connector step. The report distinguishes observed evidence, simulation and manual work instead of marking missing evidence as a pass.

Safe behavior: Initialization or evidence gaps do not become a manual bypass to a pass.

Limit / residual risk: Synthetic initialization or simulated exchange does not establish real provider execution.

Source: artifacts/api-server/src/lib/onboarding/uat-workflow-evaluator.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/onboarding/uat-workflow-evaluator.test.ts

TST-04 · Regression and demo boundaries

Status: Implemented

Risk addressed: Mistaking limited test, synthetic or demo evidence for live assurance.

Control: Unit, integration and browser checks plus controlled demonstrations support change assurance.

Business use case: A release team changes an onboarding flow and demonstrates it to a client. Regression checks should cover denial and recovery as well as success; demo activity remains distinct from real business outcomes.

Safe behavior: Tests should exercise denial, recovery, scope changes and uncertainty as well as success.

Limit / residual risk: Tests found in source are not a claim that the latest suite has passed; volunteer delivery still needs authorization.

Source: artifacts/api-server/src/lib/onboarding/guardrails.ts; artifacts/api-server/src/lib/onboarding/uat-workflow-evaluator.ts

Nearby test pointers, not run: artifacts/api-server/src/lib/onboarding/guardrails.test.ts; artifacts/api-server/src/lib/onboarding/uat-workflow-evaluator.test.ts

Metrics and evidence definitions

No live metric values are published in this register. Interpret each measurement using its actual source, denominator, provenance and limits.

MET-01 · Recorded guardrail interventions

Measurement status: Instrumented

Definition / denominator: Recorded events by guardrail/action and the screen's summed count.

Limitation: Bounded recording means this is not total attack volume; a prevention rate needs a valid attempted-action denominator.

Source or extension boundary: artifacts/api-server/src/lib/onboarding/guardrails.ts; artifacts/onboarding-agent/src/pages/guardrails.tsx

MET-02 · Security-drill outcomes

Measurement status: Scenario evidence

Definition / denominator: Step outcomes from the scenarios in the executed drill.

Limitation: Identify scope and run date; no fresh drill was run for this document.

Source or extension boundary: artifacts/api-server/src/lib/onboarding/security-drill.ts

MET-03 · Human-review indicator

Measurement status: Derived operational rate

Definition / denominator: Filtered cases with recorded all-time approval history / all filtered cases.

Limitation: Counts review records, not necessarily completed human decisions; not an AI-correctness measure.

Source or extension boundary: artifacts/onboarding-agent/src/pages/analytics.tsx

MET-04 · Autonomy indicator

Measurement status: Derived operational rate

Definition / denominator: Completed filtered cases without recorded all-time approval history / completed filtered cases.

Limitation: No recorded approval is not proof of safe AI autonomy; underlying completion provenance matters.

Source or extension boundary: artifacts/onboarding-agent/src/pages/analytics.tsx

MET-05 · Exception rate

Measurement status: Derived operational rate

Definition / denominator: Filtered cases currently in the exception stage / all filtered cases.

Limitation: Current-state measure, not all historical exceptions or a fairness score.

Source or extension boundary: artifacts/onboarding-agent/src/pages/analytics.tsx

MET-06 · AI request budgets

Measurement status: Instrumented

Definition / denominator: Recorded inputBytes, output-token allowance and budget approval/rejection steps.

Limitation: Conservative size bound and allowance, not actual tokens consumed, spend or response correctness.

Source or extension boundary: artifacts/api-server/src/lib/hro-context/ai-budget.ts; artifacts/api-server/src/lib/hro-context/manager.ts

MET-07 · Execution continuity

Measurement status: Trace evidence

Definition / denominator: Attempt status/timestamps, step codes and correlation/parent links.

Limitation: An execution status is not case completion, SLA evidence or professional approval.

Source or extension boundary: artifacts/api-server/src/lib/hro-context/manager.ts; artifacts/api-server/src/routes/hro-context.ts

MET-08 · SLA and average resolution time

Measurement status: Not measured in current dashboard

Definition / denominator: The main Analytics summary shows insufficient data for these two measures.

Limitation: Do not substitute current checklist state, estimates or simulated results for dated outcome evidence.

Source or extension boundary: artifacts/onboarding-agent/src/pages/analytics.tsx

MET-09 · Answer correctness and unsupported claims

Measurement status: Roadmap

Definition / denominator: Reviewed benchmark answers passing correctness/support criteria / eligible evaluated answers.

Limitation: Requires approved ground truth, dataset coverage, versions and uncertainty reporting; no value claimed.

Source or extension boundary: artifacts/api-server/src/lib/hr-policy-ai.ts

MET-10 · Appropriate abstention

Measurement status: Roadmap

Definition / denominator: Correctly withheld answers / evaluated questions requiring abstention; also report unnecessary withholding.

Limitation: The assistant has abstention outcomes, but an outcome is not an evaluated aggregate quality rate.

Source or extension boundary: artifacts/api-server/src/lib/hr-policy-ai.ts

MET-11 · Fairness disparities

Measurement status: Roadmap

Definition / denominator: Reviewed paired-case differences and lawful cohort outcomes where a permitted analysis exists.

Limitation: Report sample sizes and context; do not collect real protected traits without separately approved purpose and safeguards.

Source or extension boundary: artifacts/api-server/src/lib/onboarding/guardrails.ts

MET-12 · Privacy leakage and recovery assurance

Measurement status: Roadmap

Definition / denominator: Prohibited disclosures in scoped tests, protected-data coverage, verified recovery outcomes and latency with defined denominators.

Limitation: Existing blocking/recovery controls are not a published leakage rate, recovery SLO or full assurance score.

Source or extension boundary: artifacts/api-server/src/lib/onboarding/sensitive-access.ts; artifacts/api-server/src/lib/onboarding/effect-journal.ts

Roadmap — additional assurance

These improvements are not described as completed current assurance. No rollout date, legal certification or provider coverage is promised.

MAP-01 · Consolidated compliance assurance

Status: Roadmap. Map reviewed legal obligations to controls, owners and evidence; assemble consolidated gap-aware evidence packs and independent assessments.

Existing governance review and audit records remain useful but are not certification.

Suggested reviewer: Compliance / legal / audit

MAP-02 · Expanded live authenticity coverage

Status: Roadmap. Approve and validate selected issuer/provider adapters, source revocation and freshness coverage for required document types.

Signed-result infrastructure is already present; commercial source coverage is configuration- and provider-dependent.

Suggested reviewer: Verification / procurement / security

MAP-03 · Systematic answer-quality evaluation

Status: Roadmap. Use business-reviewed synthetic questions and expected outcomes across policy dates, audiences, contradictory evidence and model changes.

Broader benchmark work is underway separately; this pack does not claim it has shipped or publish an accuracy result.

Suggested reviewer: AI assurance / domain-policy owner

MAP-04 · Fairness evaluation and challenge process

Status: Roadmap. Introduce reviewed paired scenarios, governed disparity analysis and a dedicated independent challenge/appeal process for relevant AI-supported decisions.

Fairness work is underway separately; human oversight does not establish bias-free decisions.

Suggested reviewer: AI assurance / HR / legal

MAP-05 · Consolidated assurance reporting

Status: Roadmap. Bring quality, privacy, control, provider and recovery evidence into defined reports with thresholds, denominators, owners and evidence dates.

Existing operational counts and source records are not a completed responsible-AI scorecard.

Suggested reviewer: Security operations / AI assurance

Deployment evidence to obtain

Not verified in this review. These are evidence requirements, not assertions that the services lack the capability.

DEP-01 · Identity-provider posture

Tenant MFA, SSO, session settings and administrator recovery configuration.

DEP-02 · Encryption and key management

Transport/storage coverage, key ownership and rotation, backup encryption and relevant provider contracts.

DEP-03 · Residency and international transfer

Actual application, database, storage, AI and channel-provider locations and transfer arrangements.

DEP-04 · AI-provider data-use terms

Training use, provider retention, subprocessors, deletion commitments and contractual restrictions.

DEP-05 · Incident response and independent security assessment

SIEM integration, response ownership, vulnerability management and fresh independent penetration-test evidence.

DEP-06 · Recovery and compliance attestations

Verified backup/restore scope, RTO/RPO evidence and any applicable external certifications. Existing audit-provider drills do not establish full service disaster recovery.

Acceptance principle
Control presence, approved configuration, verified operational evidence and measured results are different claims. Record unresolved items instead of inferring assurance.